UPTAG
UNIVERSIDAD POLITÉCNICA TERRITORIAL DE FALCÓN ALONSO GAMERO

PNF Informática

Centenario ALONSO GAMERO 1923 - 2023

INFORME DE AUDITORÍA

SISTEMA DE GESTÍON DE NOTAS (UCS)



TSU. Pachano P. Emanuel Jesus
TSU. Rodriguez H. Diego Alejandro

Índice

1. Resumen ..... Pag 04

2. Leyenda ..... Pag 05

3. Los 10 principales riesgos de seguridad de OWASP ..... Pag 06

4. Resumen Gráfico ..... Pag 07

5. Módulo: Autenticación ..... Pag 08

    5.1 Uso inseguro de cookies para recordar contraseñas ..... Pag 09

    5.2 Uso de CAPTCHA que afecta la usabilidad ..... Pag 10

    5.3 Registro de nuevos usuarios innecesario y disfuncional ..... Pag 11

6. Módulo: Editar Perfil ..... Pag 12

    6.1 Vulnerabilidad de XSS en el formulario de edición de perfil ..... Pag 13

    6.2 Escalada de privilegios por inyección SQL ..... Pag 14

    6.3 Validación insuficiente en campos de respuesta ..... Pag 15

7. Módulo: Alumno ..... Pag 16

    7.1 Validación insuficiente en registro de alumnos ..... Pag 17

8. Módulo: Carrera ..... Pag 18

    8.1 Error en eliminación de registro por llave foránea ..... Pag 19

9. Módulo: Condición ..... Pag 20

    9.1 Validación insuficiente en formulario de condiciones ..... Pag 21

10. Módulo: Dedicaciones ..... Pag 22

    10.1 Error en eliminación de registro por llave foránea ..... Pag 23

Índice

11. Módulo: Docente ..... Pag 24

11.1 Validación insuficiente de teléfono y correo en docente ..... Pag 25

12. Módulo: Notas ..... Pag 26

12.1 Advertencia por acceso a índice nulo ..... Pag 27

13. Módulo: Usuarios ..... Pag 28

13.1 Riesgo en la edición de usuarios administradores ..... Pag 29

13.2 Visualización completa de los usuarios ..... Pag 30

13.3 Ingreso libre de preguntas de seguridad en formularios ..... Pag 31

14. Módulo: Bitácora ..... Pag 32

14.1 Bitácora sin integración funcional ..... Pag 33

15. Inspección del Código ..... Pag 34

15.1 Falta de Sanitización ..... Pag 35

15.2 Fallo en el manejo de sesión tras redirección por inactividad ... Pag 36

15.3 Configuración Incorrecta de Seguridad ..... Pag 37

15.4 Falta de Gestión de Versiones y Copias de Seguridad ..... Pag 38

15.5 Código Espagueti ..... Pag 39

15.6 Diseño Inseguro ..... Pag 40

16. Testing ..... Pag 41

16.1 Pruebas de Exploración ..... Pag 42

16.2 Pruebas de Rendimiento ..... Pag 43

17. Observaciones y Recomendaciones ..... Pag 44

17.1 Visión General de lo Analizado .....Pag 45

Resumen

El siguiente informe presenta una evaluación técnica del sistema de gestión de notas de la "UCS", en la que se identifican diversas debilidades relacionadas con validaciones incompletas, errores en la lógica de negocio, problemas de integridad referencial y elementos de usabilidad no resueltos. Muchos de estos hallazgos no constituyen vulnerabilidades críticas desde el punto de vista de seguridad, pero sí afectan directamente la funcionalidad, consistencia de los datos y experiencia general del usuario. Entre los problemas detectados destacan formularios con controles insuficientes, errores por restricciones de claves foráneas no gestionadas correctamente, formularios públicos redundantes o inoperativos, y mensajes incorrectos que inducen a confusión.

Cada hallazgo ha sido clasificado con un nivel de riesgo, acompañado de una descripción técnica clara y recomendaciones concretas para su corrección. El objetivo de este análisis es servir como guía para futuras mejoras en el sistema, garantizando una mayor estabilidad, confiabilidad y facilidad de uso. Se recomienda a los encargados del desarrollo y mantenimiento del sistema priorizar las observaciones aquí planteadas, con el fin de elevar los estándares de calidad del software y reducir el riesgo operativo en un entorno crítico como lo es el control académico universitario.

Leyenda

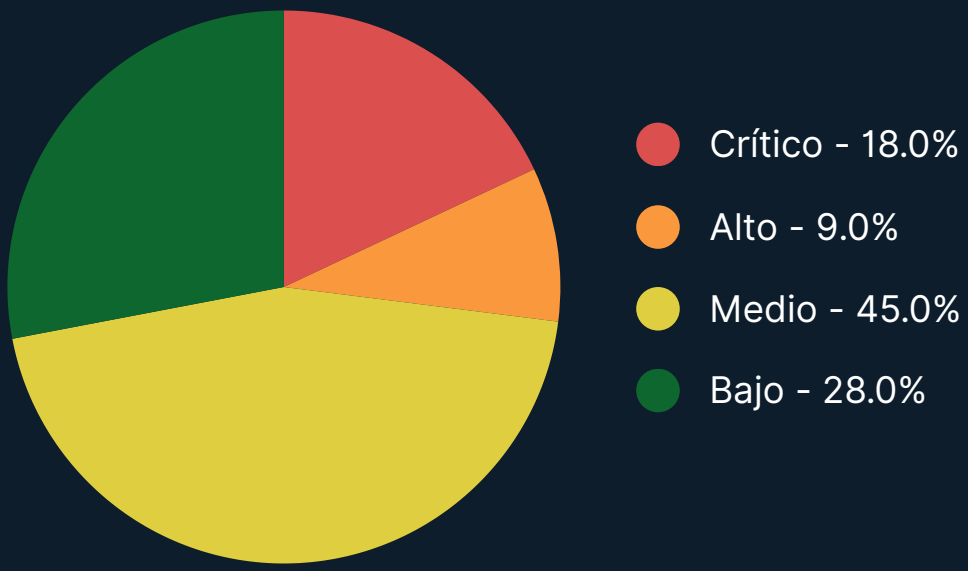
Nivel de Riesgo	Descripción
Crítico	Vulnerabilidad que puede ser explotada para acceder a información confidencial, tomar el control del sistema o provocar daños severos
Alto	Vulnerabilidad de gravedad considerable que puede ser utilizada para generar daños importantes en el sistema
Medio	Debilidad explotable que podría permitir acceso no autorizado, comprometiendo moderadamente la confidencialidad o integridad.
Bajo	Deficiencia que podría permitir acceso restringido a información no crítica o afectar levemente al sistema y su usabilidad.

OWASP TOP 10

Descripción General	Color Representativo
A01:2021-Broken Access Control	
A02:2021-Cryptographic Failures	
A03:2021-Injection	
A04:2021-Insecure Design	
A05:2021-Security Misconfiguration	
A06:2021-Vulnerable and Outdated components	
A07:2021-Identification and Authentication Failures	
A08:2021-Software and Data Integrity Failures	
A09:2021-Security Logging and Monitoring Failures	
A10:2021-Server-Side Request forgery (SSRF)	

Resumen Gráfico

Distribución de vulnerabilidad



Puntuación de Riesgo General



Módulo: Autenticación



Uso inseguro de cookies para recordar contraseñas

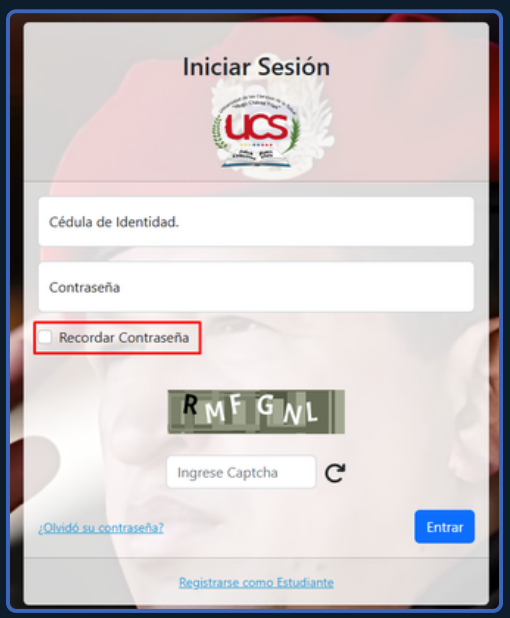
Identificación	Riesgo	Estatus
001	Medio	Nuevo

Descripción:

La opción "Recordar contraseña" en el login no funciona correctamente, pero intenta almacenar la contraseña en cookies. Aunque la contraseña está cifrada, esta práctica expone al sistema a riesgos como el robo de cookies o ataques XSS, lo que pone en peligro la seguridad de las cuentas.

Recomendación:

Eliminar la opción si no se va a implementar correctamente, o si se desea mantener, utilizar un sistema seguro de tokens de autenticación temporales almanenados en el servidor y asegurar las cookies con los atributos “HttpOnly” y “Secure”.




```php
if (isset($_POST['inputRememberPassword']) &&
$_POST['inputRememberPassword'] == 'on') {
    $expires = time() + 86400 * 30;
    setcookie('rememberPassword', $contraseña,
    $expires, "/");
}
header("Location: ../settings.php");
exit(); }
}
```

Ubicación: UCS-A/index.php

Uso de CAPTCHA que afecta la usabilidad

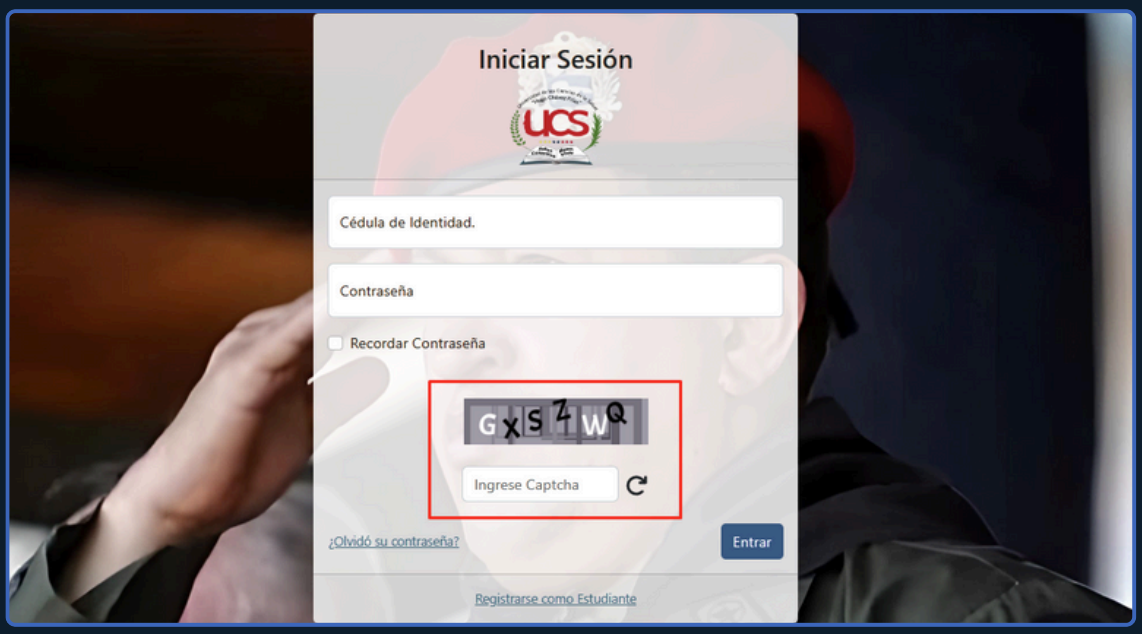
Identificación	Riesgo	Estatus
002	Bajo	Nuevo

Descripción:

El formulario de inicio de sesión utiliza un CAPTCHA visual que puede afectar la experiencia del usuario. La imagen puede ser difícil de leer, además, no ofrece alternativas accesibles (como audio). Esto puede generar frustración, especialmente en usuarios con discapacidades o en dispositivos móviles.

Recomendación:

Se sugiere implementar alternativas más amigables como reCAPTCHA de Google, que ofrece validación invisible o basada en comportamiento. Asimismo, se deben ofrecer alternativas accesibles como una opción de audio para personas con dificultades visuales.



Ubicación: UCS-A/index.php

Registro de nuevos usuarios innecesario y disfuncional

Identificación	Riesgo	Estatus
003	Bajo	Nuevo

Descripción:

El sistema poseé un formulario de registro público para estudiantes, pero esta función es redundante e incompatible con el modelo de administración del sistema, ya que los administradores pueden registrar estudiantes directamente. Además, el formulario no funciona correctamente: aunque el número de cédula del estudiante exista dentro de la base de datos, el sistema devuelve un error por una mala validación en el archivo db_register.php.

Recomendación:

Se recomienda eliminar el formulario de registro público para evitar redundancias e inconsistencias en el sistema. En su lugar, se debe mantener y fortalecer la funcionalidad que permite a los administradores registrar a los estudiantes directamente.



Ubicación: UCS-A/index.php

Módulo: Editar Perfil



Vulnerabilidad de XSS en el formulario de edición de perfil

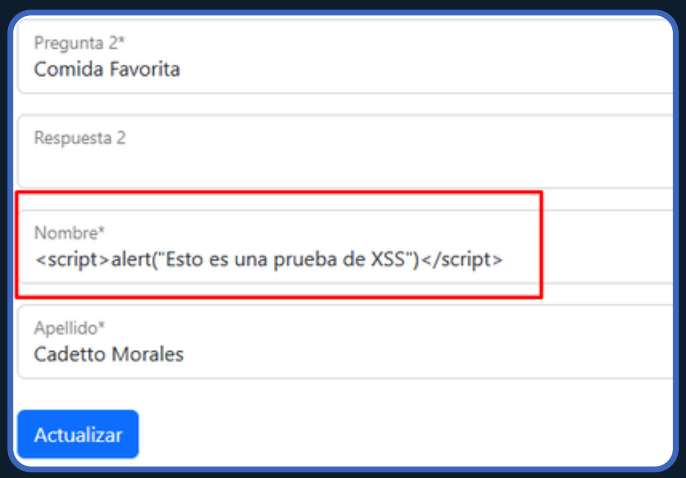
Identificación	Riesgo	Estatus
004	Crítico	Nuevo

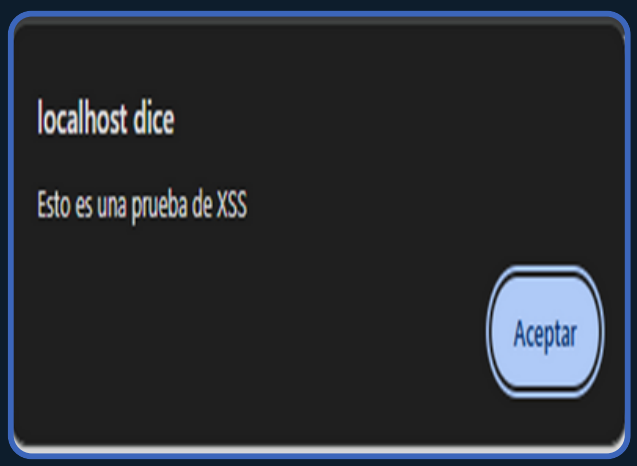
Descripción:

El formulario de edición de perfil es vulnerable a ataques de Cross-Site Scripting (XSS) debido a la falta de validación y saneamiento de las entradas del usuario. Esto permite la inyección de scripts maliciosos, lo que podría comprometer la seguridad de la aplicación y los datos del usuario.

Recomendación:

Se recomienda implementar un adecuado saneamiento y validación de los datos ingresados por el usuario para evitar la ejecución de scripts maliciosos. Además, se debe considerar la adopción de políticas de seguridad como Content Security Policy (CSP) para mitigar estos riesgos.





Ubicación: UCS-A/settings.php

Escalada de privilegios por inyección SQL

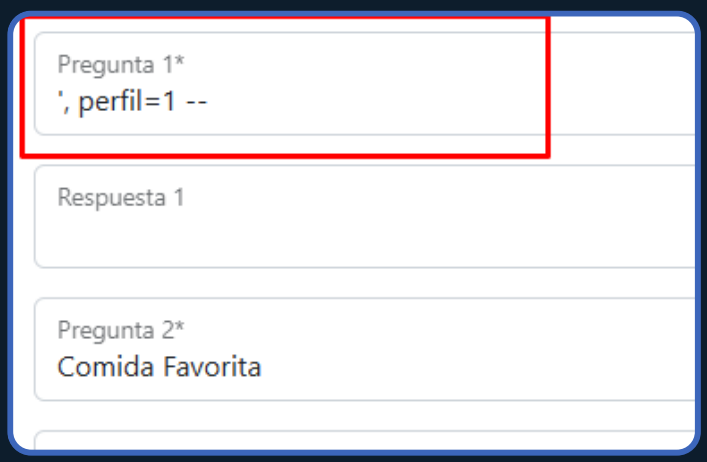
Identificación	Riesgo	Estatus
005	Crítico	Nuevo

Descripción:

Se encontró una vulnerabilidad de inyección SQL en el campo “Pregunta 1" del formulario, que permite modificar la columna “perfil” en la tabla usuario. Al inyectar el código ', perfil=1 --, se cambia el valor del perfil a 1, lo que otorga el rol de "administrador" a todos los usuarios afectados por la consulta. Esta vulnerabilidad permite la escalada de privilegios de manera no autorizada, ya que al no validar correctamente los datos ingresados, es posible manipular la base de datos y otorgar privilegios elevados sin restricciones.

Recomendación:

Se recomienda implementar validación y sanitización adecuadas de las entradas del usuario para evitar inyecciones SQL, utilizando sentencias preparadas (prepared statements) en lugar de concatenar directamente las variables en las consultas SQL.





Ubicación: UCS-A/settings.php

Validación insuficiente en campos de respuesta

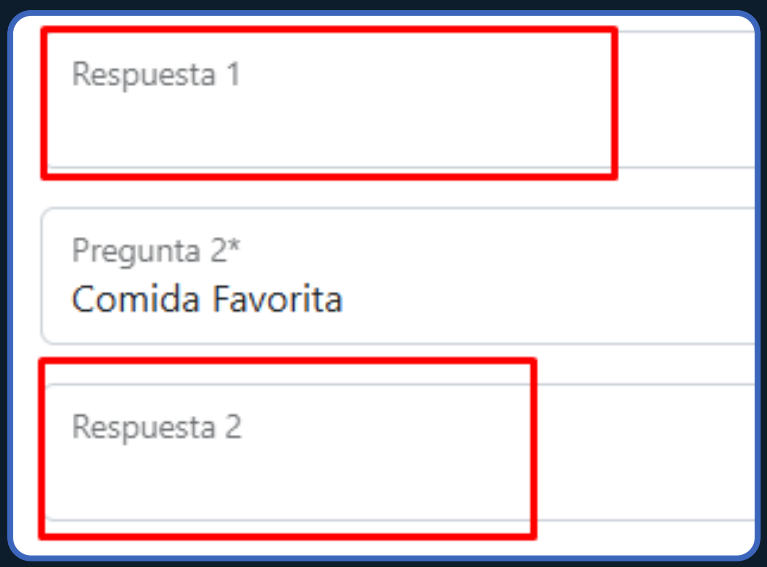
Identificación	Riesgo	Estatus
006	Alto	Nuevo

Descripción:

El sistema permite que los campos de “respuesta 1” y “respuesta 2” se actualicen con solo espacios en blanco, ya que la validación actual no los considera entradas inválidas. Esto puede generar que se almacenen datos vacíos en la base de datos, afectando la calidad del contenido y la experiencia del usuario.

Recomendación:

Implementar una validación que elimine los espacios en blanco antes de enviar los datos, tanto en el cliente como en el servidor, para evitar que se guarden entradas sin contenido significativo. Además, se sugiere proporcionar retroalimentación clara al usuario cuando se detecten entradas inválidas para mejorar la usabilidad.



Ubicación: UCS-A/settings.php

Módulo: Alumno



Validación insuficiente en registro de alumnos

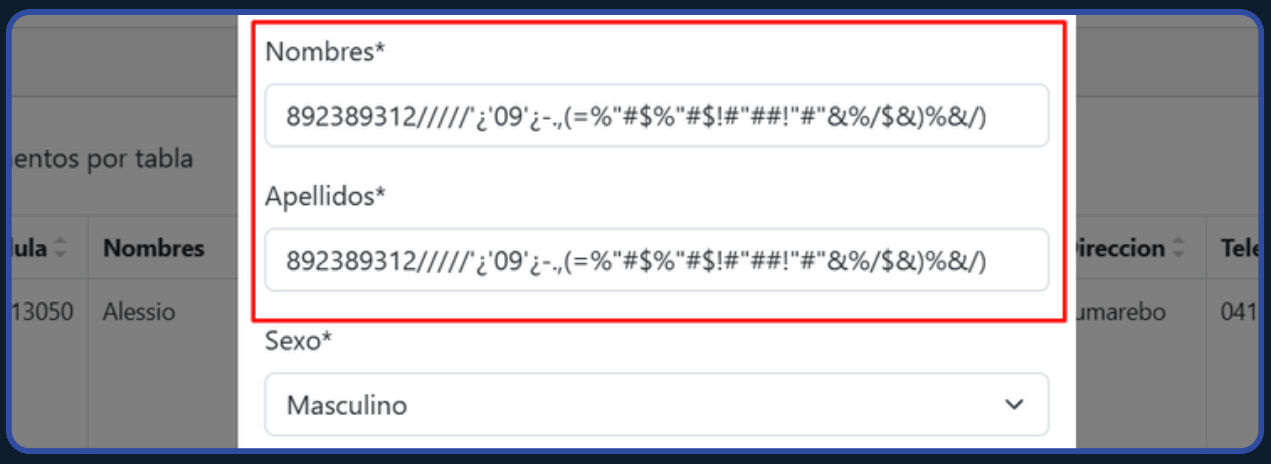
Identificación	Riesgo	Estatus
007	Medio	Nuevo

Descripción:

El formulario de registro de alumnos permite ingresar caracteres no alfabéticos en los campos de “nombres” y “apellidos”, incluyendo números y símbolos especiales. Esto afecta la integridad de los datos almacenados, dificulta procesos posteriores de búsqueda o reporte, y puede ser aprovechado para inyecciones o pruebas maliciosas si no se controla adecuadamente.

Recomendación:

Implementar validaciones del lado del cliente y del servidor que limiten estos campos únicamente a caracteres alfabéticos (y excepciones justificadas como tildes o apóstrofes). Esto garantizará una entrada de datos coherente y reducirá posibles vectores de ataque o errores lógicos en el sistema.



Ubicación: UCS-A/crud_alumno.php

Módulo: Carrera



Error en eliminación de registro por llave foránea

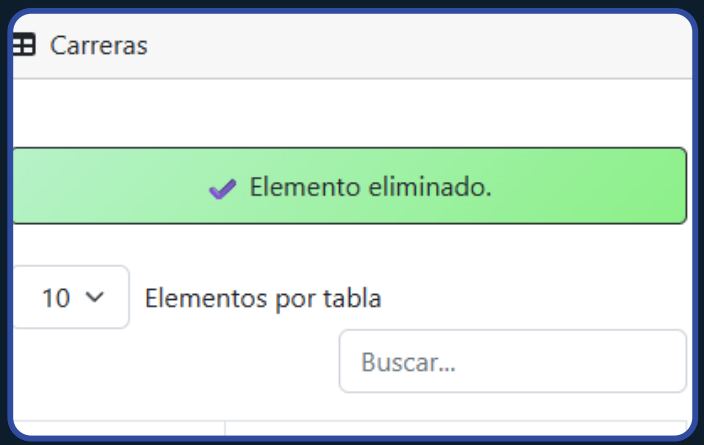
Identificación	Riesgo	Estatus
008	Medio	Nuevo

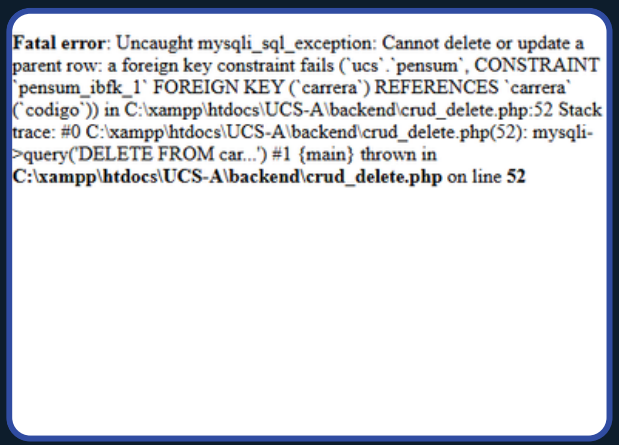
Descripción:

El sistema intenta eliminar un registro de la tabla carrera, pero falla debido a una restricción de llave foránea con la tabla pensum, que contiene registros dependientes. Esto genera un error fatal, pero el sistema muestra un mensaje de éxito (Elemento eliminado), dando una falsa impresión de que el registro fue eliminado cuando en realidad persiste en la base de datos.

Recomendación:

Se recomienda implementar un control de errores tras la consulta de eliminación, mostrando el mensaje de éxito solo si la operación fue exitosa. En caso de fallo, el sistema debe informar al usuario que no se puede eliminar el registro por dependencias existentes, sugiriendo eliminar primero los registros asociados.





Ubicación: UCS-A/crud_carrera.php

Módulo: Condición



Validación insuficiente en formulario de condiciones

Identificación	Riesgo	Estatus
009	Medio	Nuevo

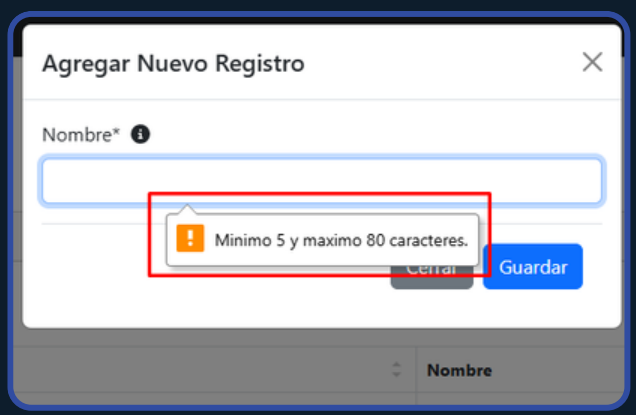
Descripción:

El formulario de agregar condición permite a los usuarios ingresar cualquier tipo de valor (letras, números, símbolos) sin restricción alguna, lo que genera un riesgo de almacenamiento de datos erróneos o inconsistentes. Además, el límite de 80 caracteres es excesivo, lo que puede resultar en la entrada de valores no válidos o inadecuados para la naturaleza de la condición del docente.

Recomendación:

Implementar validaciones más estrictas para el campo "Nombre", limitando los caracteres a un rango apropiado (por ejemplo, 5-30 caracteres) y restringiendo la entrada a caracteres alfanuméricos y símbolos específicos que sean relevantes para la descripción de la condición. Esto mejorará la integridad de los datos y evitará problemas futuros en la base de datos.





Ubicación: UCS-A/crud_condicion.php

Módulo: Dedicaciones



Error en eliminación de registro por llave foránea

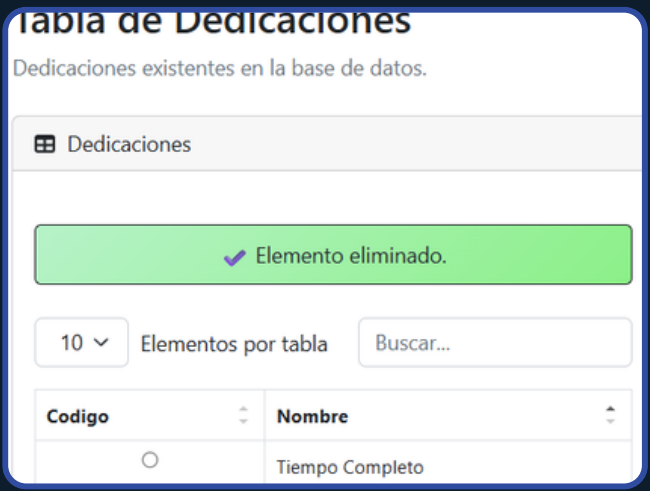
Identificación	Riesgo	Estatus
010	Medio	Nuevo

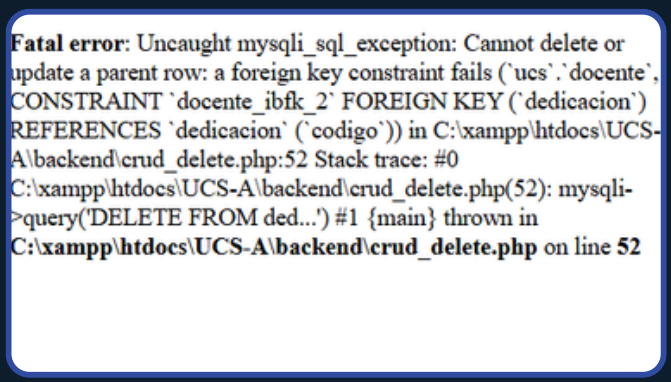
Descripción:

El sistema intenta eliminar un registro de la tabla dedicación, pero falla debido a una restricción de llave foránea con la tabla docente, que contiene registros dependientes. Esto genera un error fatal, pero el sistema muestra un mensaje de éxito (Elemento eliminado), dando una falsa impresión de que el registro fue eliminado cuando en realidad persiste en la base de datos.

Recomendación:

Se recomienda implementar un control de errores tras la consulta de eliminación, mostrando el mensaje de éxito solo si la operación fue exitosa. En caso de fallo, el sistema debe informar al usuario que no se puede eliminar el registro por dependencias existentes, sugiriendo eliminar primero los registros asociados.





Ubicación: UCS-A/crud_dedicacion.php

Módulo: Docente



Validación insuficiente de teléfono y correo en docentes

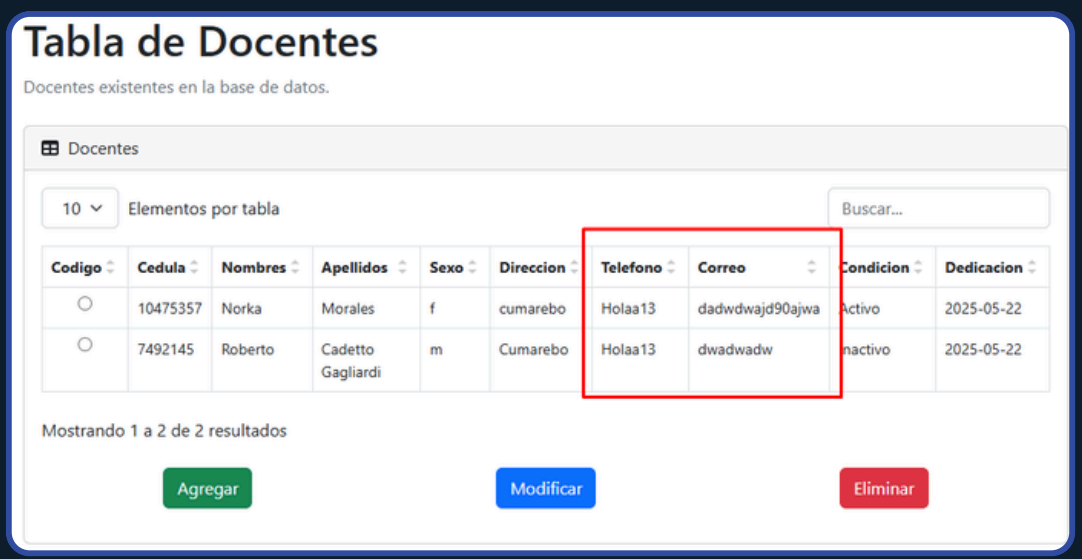
Identificación	Riesgo	Estatus
011	Medio	Nuevo

Descripción:

En el módulo de docentes, los campos teléfono y correo solo están validados en el frontend mediante atributos HTML. Esto permite que, al modificar el código desde el inspector del navegador, se puedan ingresar valores inválidos, comprometiendo la integridad de los datos. Esta debilidad facilita el almacenamiento de información incorrecta o maliciosa.

Recomendación:

Implementar validación en el backend para asegurar que los datos ingresados en los campos de teléfono y correo cumplan con el formato esperado. También se deben sanitizar los datos para evitar posibles entradas maliciosas.



Ubicación: UCS-A/crud_docente.php

Módulo: Notas



Advertencia por acceso a índice nulo

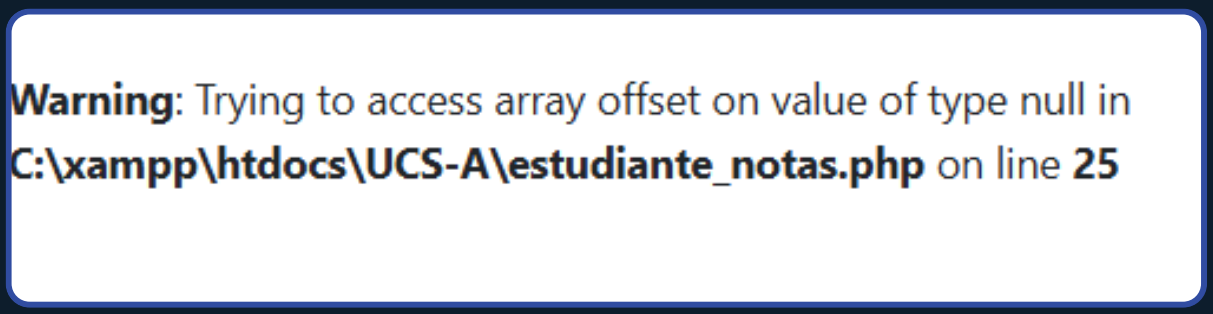
Identificación	Riesgo	Estatus
012	Bajo	Nuevo

Descripción:

Al ingresar al sistema con un usuario con rol de alumno y acceder al módulo de notas, se presenta la siguiente advertencia: Warning: Trying to access array offset on value of type null in C:\xampp\htdocs\UCS-A\estudiante_notas.php on line 25. Esto ocurre porque el sistema intenta acceder a un índice de un valor que es null, lo que sugiere que la consulta previa no retorna resultados o no se validó correctamente el contenido antes de intentar acceder al mismo.

Recomendación:

Agregar una validación que confirme que la variable no sea null antes de acceder a sus índices. Esto previene errores en tiempo de ejecución y mejora la experiencia del usuario evitando mensajes técnicos innecesarios. También se recomienda verificar si los datos que deberían poblar esa variable están siendo correctamente recuperados.



Ubicación: UCS-A/estudiante_notas.php

Módulo: Usuarios



Riesgo en la edición de usuarios administradores

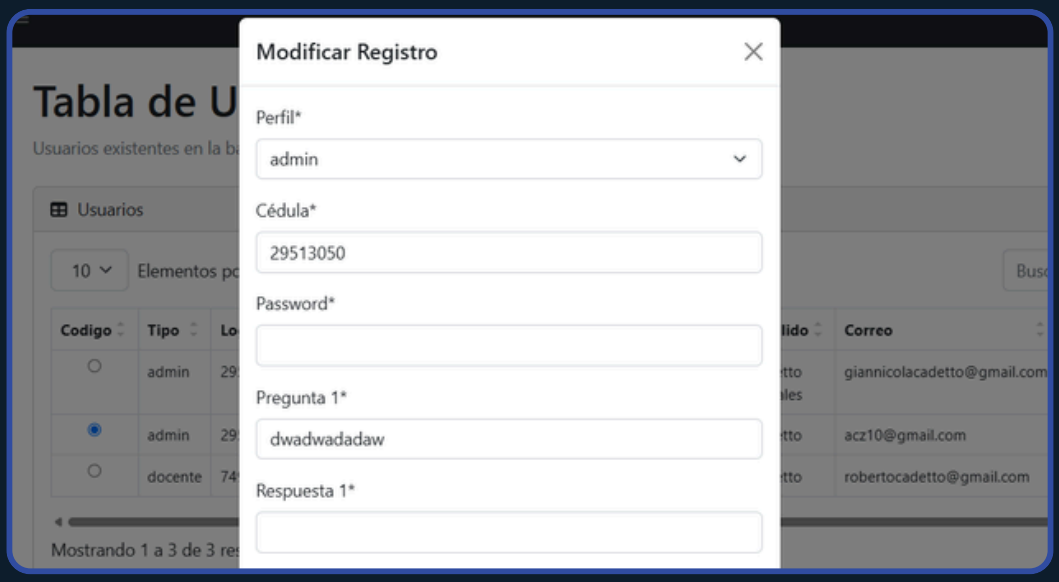
Identificación	Riesgo	Estatus
013	Crítico	Nuevo

Descripción:

Al seleccionar un usuario con rol de administrador, el sistema muestra el formulario de edición sin validación previa. Esto permite que un usuario con privilegios modifique los datos del administrador, como la contraseña y las respuestas de seguridad, y luego eliminarlo, ya que tendría acceso a la información necesaria para completar el proceso de eliminación.

Recomendación:

Al seleccionar un usuario con rol de administrador, antes de mostrar el formulario de edición, debería solicitarse una validación adicional, similar a la que se realiza en la función de eliminación. Esto garantizaría que solo los usuarios autorizados puedan modificar datos críticos de administradores.



Ubicación: UCS-A/crud_usuario.php

Visualización completa de los usuarios

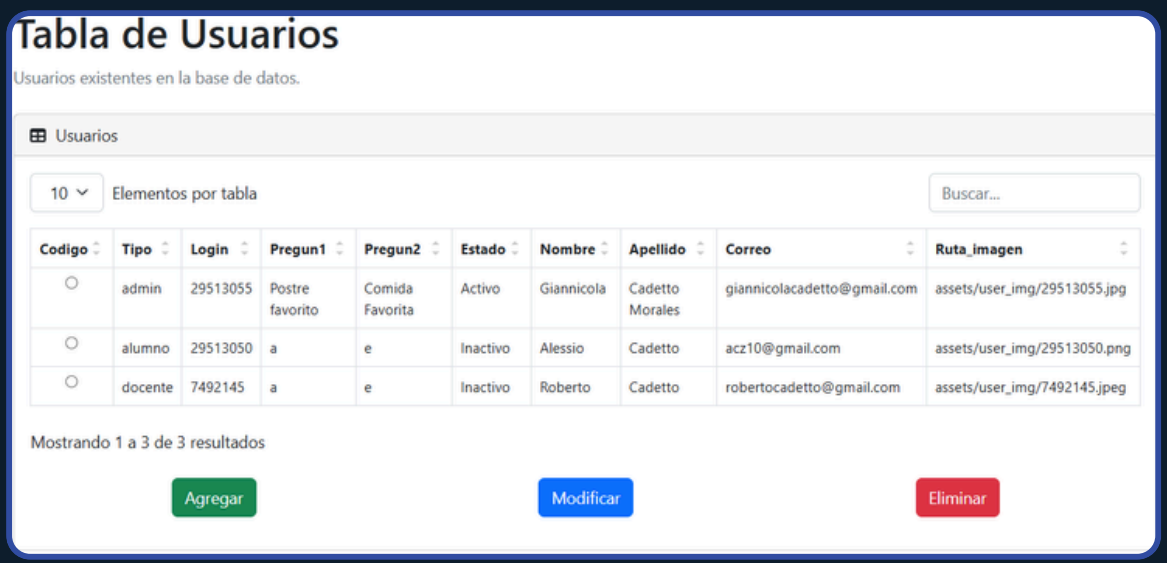
Identificación	Riesgo	Estatus
014	Medio	Nuevo

Descripción:

El módulo “crud_usuario.php” muestra todos los usuarios registrados, incluyendo al administrador principal. Esto representa un riesgo moderado, ya que expone al usuario crítico a posibles acciones maliciosas o accidentes, como su eliminación. En caso de eliminar todos los usuarios, se comprometería el acceso administrativo al sistema.

Recomendación:

Implementar una restricción en la consulta que excluya al administrador principal de la visualización en el listado general de usuarios. Esto fortalecería la seguridad del módulo y preservaría la integridad del acceso al sistema.



Ubicación: UCS-A/crud_usuario.php

Ingreso libre de preguntas de seguridad en formularios

Identificación	Riesgo	Estatus
015	Medio	Nuevo

Descripción:

Tanto al agregar como al modificar un usuario, se permite ingresar cualquier pregunta de seguridad como texto libre, lo que genera poca estandarización y permite introducir contenido irrelevante, incoherente u ofensivo. Además, al aceptar cualquier tipo de carácter, existe el riesgo de inyecciones o errores de interpretación si no hay sanitización adecuada.

Recomendación:

Reemplazar los campos de texto de preguntas de seguridad por un selector con un conjunto de preguntas predefinidas y controladas. Esto mejora la coherencia del sistema, reduce riesgos de seguridad y facilita el manejo de los datos.



Ubicación: UCS-A/crud_usuario.php

Módulo: Bitácora



Bitácora sin integración funcional

Identificación	Riesgo	Estatus
016	Bajo	Nuevo

Descripción:

La bitácora es accesible solo por URL y requiere registros manuales, lo que limita su funcionalidad. Debe registrar automáticamente acciones clave como eliminaciones o modificaciones en tablas, para garantizar la trazabilidad y facilitar la auditoría del sistema.

Recomendación:

Reconfigurar la bitácora para registrar automáticamente todas las acciones relevantes del sistema y hacerla accesible desde la barra de navegación principal, garantizando su integridad y facilidad de acceso para los usuarios autorizados.



Ubicación: UCS-A/crud_bitacora.php

Inspección del Código



Falta de Sanitización

Identificación	Riesgo	Estatus
017	Crítico	Nuevo

Descripción:

En los archivos PHP del backend, especialmente en los procesos de autenticación y registro de usuarios, se observa la falta de sanitización adecuada de los datos recibidos del usuario. Además, se emplean consultas SQL directas sin sentencias preparadas, exponiendo la aplicación a posibles ataques de inyección SQL.

Recomendación:

Se debe utilizar sentencias preparadas como mysqli_prepare() y mysqli_stmt_bind_param() para prevenir inyecciones SQL. Además, es necesario sanitizar las entradas del usuario con funciones como htmlspecialchars() y strip_tags() para evitar la ejecución de código malicioso y asegurar que los datos introducidos no afecten la seguridad del sistema.

```php
$table = strtolower($_GET['table']);
$conn = mysqli_connect("localhost:3306","root","", "ucs");
mysqli_set_charset($conn, "utf8");

if (isset($_POST['login'])) {
    $login = $_POST['login'];
    $querycheck = "SELECT login FROM usuario WHERE login LIKE '$login'";
    $result = mysqli_query($conn, $querycheck);
    if (mysqli_num_rows($result) != 0) {
        header('Location: ../crud_usuario.php?error=El usuario ya existe');
        exit;
    }
}
if (!$conn) {
    die("Connection failed: " . mysqli_connect_error());
}
```

```php
$placeholders = implode(", ", array_fill(0, count
($columns), "?"));

$query = "INSERT INTO $table (" . implode(", ",
$columns) . ") VALUES ($placeholders)";

$stmt = mysqli_prepare($conn, $query);
$refs = str_repeat("s", count($data));
mysqli_stmt_bind_param($stmt, $refs, ...$data);

$result = mysqli_stmt_execute($stmt);
```

Ubicación: /UCS-A

Fallo en el manejo de sesión tras redirección por inactivida

Identificación	Riesgo	Estatus
018	Alto	Nuevo

Descripción:

El sistema cuenta con un temporizador JavaScript “timer.js” que, tras 5 minutos de inactividad, redirige al usuario a la pantalla de inicio de sesión (index.php). Sin embargo, esta redirección no cierra la sesión activa, lo que permite al usuario volver a acceder al sistema simplemente ingresando la URL directa de cualquier módulo. Esto representa una falla crítica en la gestión de sesiones, ya que compromete la seguridad del sistema al dejar sesiones abiertas incluso después de un aparente cierre por inactividad.

Recomendación:

Modificar el código para que, además de redirigir al login, se cierre correctamente la sesión del usuario (por ejemplo, mediante session_destroy() o session_unset() en el backend). De esta forma, se evitaría que los usuarios permanezcan autenticados tras la inactividad y se garantizaría un control más seguro de las sesiones.

```
var temporizador;

function ini() {
  temporizador = setTimeout('location="index.php"',300000); // 5 minutos
}
function parar() {
  clearTimeout(temporizador);
  temporizador = setTimeout('location="index.php"',300000); // 5 minutos
}
```

Ubicación: /UCS-A

Configuración Incorrecta de Seguridad

Identificación	Riesgo	Estatus
019	Medio	Nuevo

Descripción:

El sistema utiliza el usuario predeterminado de la base de datos, lo cual no es recomendable en aplicaciones ya desplegadas. Este tipo de configuración aumenta la vulnerabilidad, ya que los atacantes suelen buscar y explotar estos accesos predeterminados para obtener control sobre la base de datos.

Recomendación:

Se recomienda crear un usuario específico y con permisos mínimos necesarios para gestionar la base de datos, asegurando que las credenciales sean seguras y evitando el uso de configuraciones predeterminadas.

```php
<?php
    ini_set('display_errors', 'On');
    $conn = mysqli_connect("localhost:3306","root","", "ucs");
mysqli_set_charset($conn, "utf8");
    if (!$conn) {
        die("Connection failed: " . mysqli_connect_error());
    }
```

Ubicación: /UCS-A

Falta de Gestión de Versiones y Copias de Seguridad

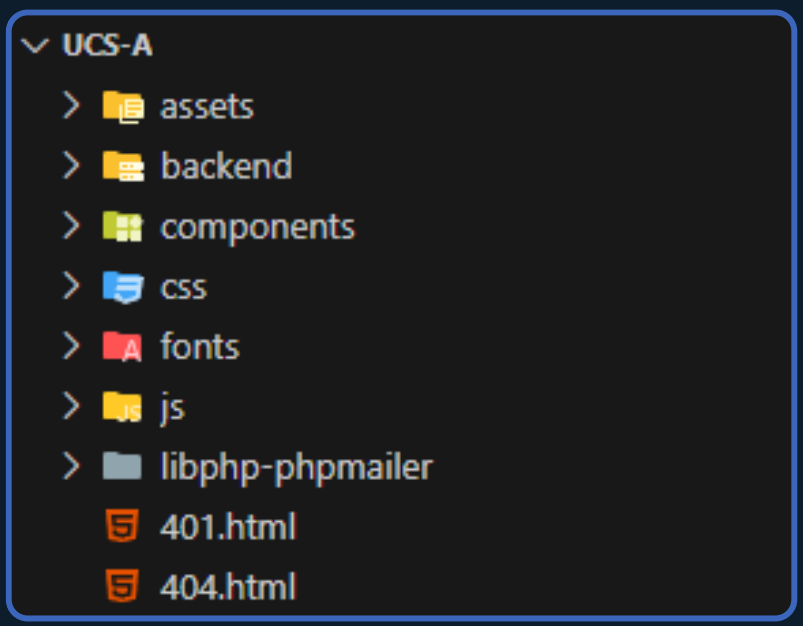
Identificación	Riesgo	Estatus
020	Medio	Nuevo

Descripción:

El sistema no utiliza un control de versiones como GIT ni está vinculado a repositorios remotos como GitHub, GitLab o Bitbucket, lo que dificulta la gestión de versiones y aumenta el riesgo de vulnerabilidad en las copias de seguridad. Esto se evidencia por la ausencia de archivos de configuración de GIT, como .git y .gitignore.

Recomendación:

Se recomienda implementar un sistema de control de versiones con GIT, vinculado a un repositorio remoto, para mejorar la gestión de cambios y fortalecer la seguridad de las copias de seguridad.



Ubicación: /UCS-A

Código Espagueti

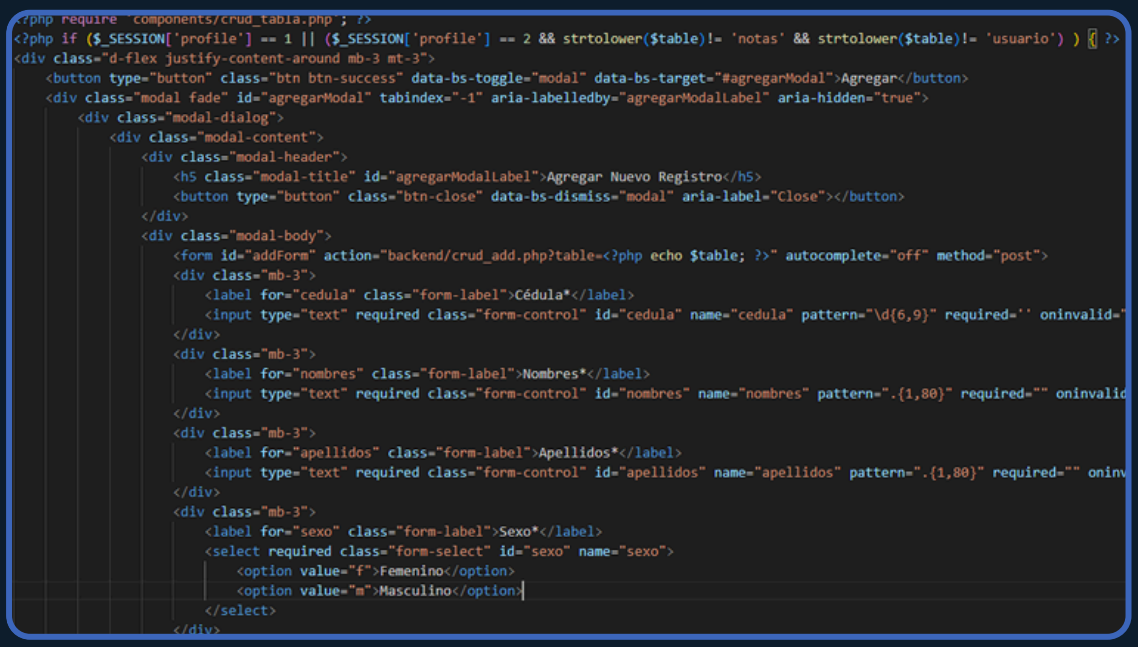
Identificación	Riesgo	Estatus
021	Bajo	Nuevo

Descripción:

El código fuente presenta un estilo extenso y desordenado, lo que dificulta su mantenimiento y escalabilidad. Esta complejidad incrementa el tiempo necesario para comprender su funcionamiento, afectando la eficiencia en futuras modificaciones o mejoras.

Recomendación:

Se recomienda refactorizar el código aplicando principios de desarrollo como el Clean Code y los principios SOLID, con el fin de mejorar su legibilidad, facilitar su mantenimiento y permitir una evolución más ordenada del sistema.



```
<?php require 'components/crud_tabla.php'; ?>
<?php if ($_SESSION['profile'] == 1 || ($_SESSION['profile'] == 2 && strtolower($table)!= 'notas' && strtolower($table)!= 'usuario') ) { ?>
<div class="d-flex justify-content-around mb-3 mt-3">
    <button type="button" class="btn btn-success" data-bs-toggle="modal" data-bs-target="#agregarModal">Agregar</button>
    <div class="modal fade" id="agregarModal" tabindex="-1" aria-labelledby="agregarModalLabel" aria-hidden="true">
        <div class="modal-dialog">
            <div class="modal-content">
                <div class="modal-header">
                    <h5 class="modal-title" id="agregarModalLabel">Agregar Nuevo Registro</h5>
                    <button type="button" class="btn-close" data-bs-dismiss="modal" aria-label="Close"></button>
                </div>
                <div class="modal-body">
                    <form id="addForm" action="backend/crud_add.php?table=<?php echo $table; ?>" autocomplete="off" method="post">
                    <div class="mb-3">
                        <label for="cedula" class="form-label">Cédula*</label>
                        <input type="text" required class="form-control" id="cedula" name="cedula" pattern="\d{6,9}" required='' oninvalid="
                    </div>
                    <div class="mb-3">
                        <label for="nombres" class="form-label">Nombres*</label>
                        <input type="text" required class="form-control" id="nombres" name="nombres" pattern=".{1,80}" required="" oninvalid
                    </div>
                    <div class="mb-3">
                        <label for="apellidos" class="form-label">Apellidos*</label>
                        <input type="text" required class="form-control" id="apellidos" name="apellidos" pattern=".{1,80}" required="" oninv
                    </div>
                    <div class="mb-3">
                        <label for="sexo" class="form-label">Sexo*</label>
                        <select required class="form-select" id="sexo" name="sexo">
                            <option value="f">Femenino</option>
                            <option value="m">Masculino</option>
                        </select>
                    </div>
```

Ubicación: /UCS-A

Diseño Inseguro

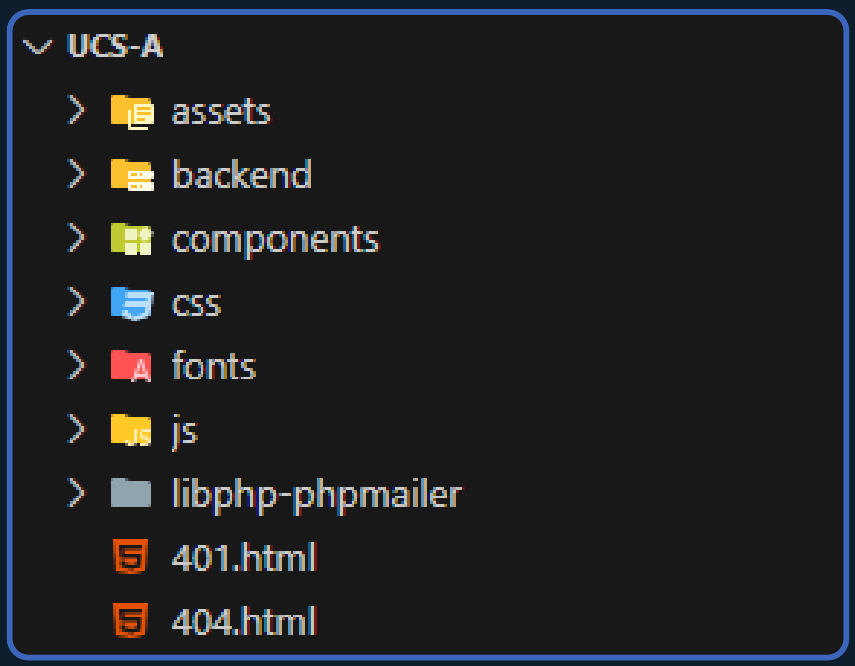
Identificación	Riesgo	Estatus
022	Bajo	Nuevo

Descripción:

El código fuente no sigue ningún patrón o arquitectura de diseño segura, lo que no solo representa una vulnerabilidad potencial, sino que también dificulta su mantenimiento y comprensión debido a la falta de un flujo de trabajo claro.

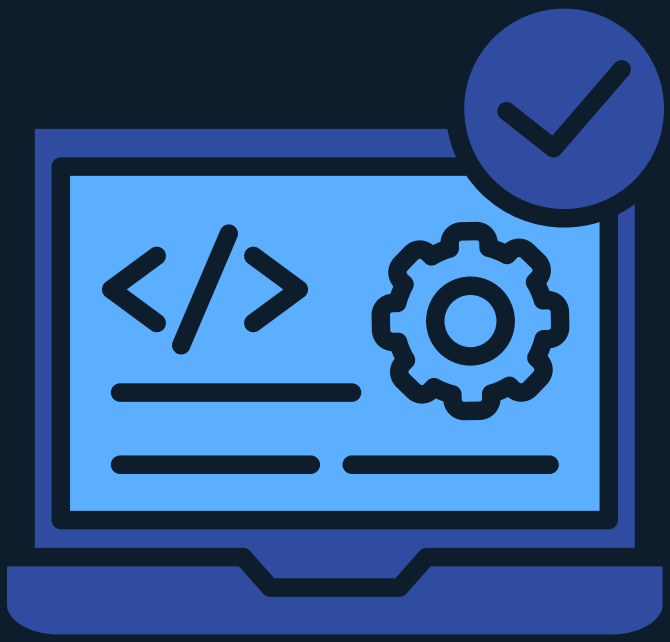
Recomendación:

Se recomienda reestructurar el proyecto aplicando un patrón de diseño o una arquitectura segura, que facilite la comprensión del código, mejore su mantenibilidad y reduzca los riesgos de seguridad.



Ubicación: /UCS-A

Testing

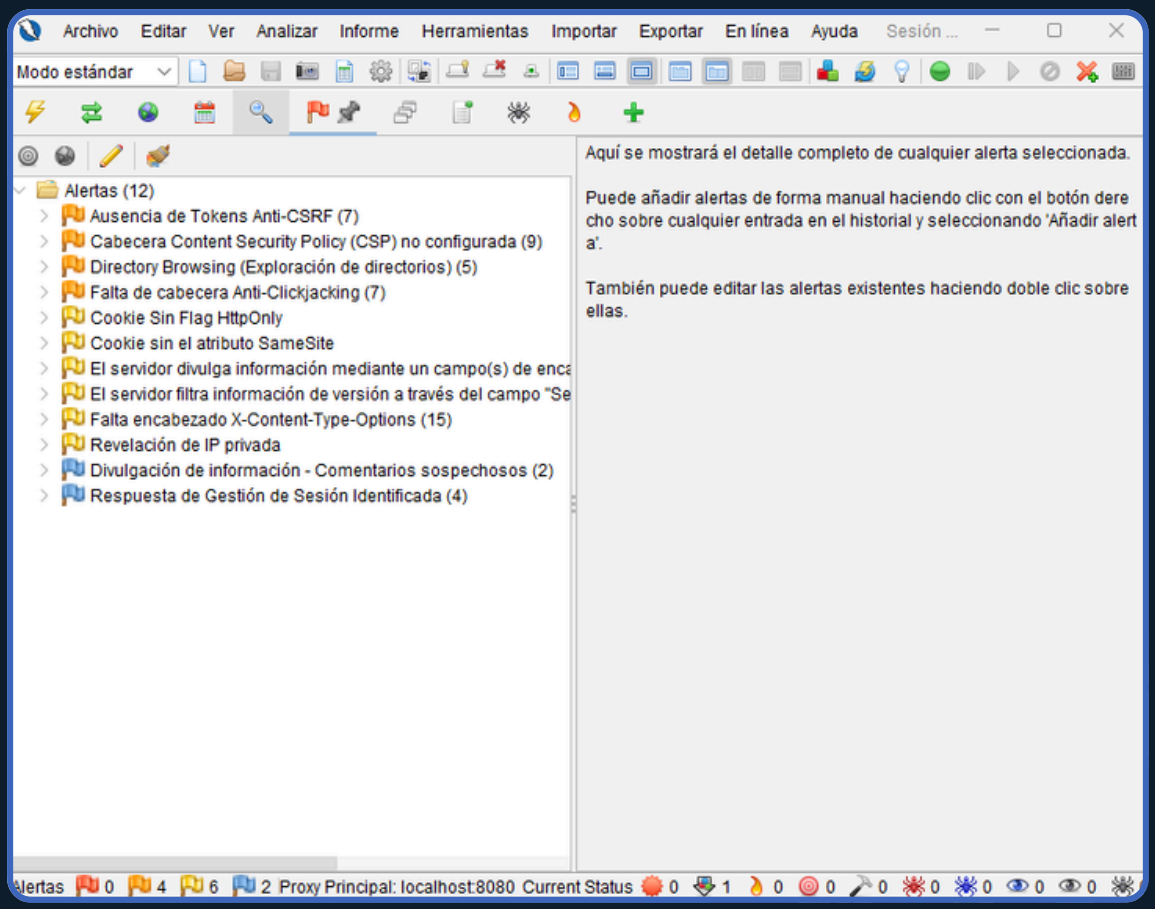


Pruebas Exploratorias

Descripción:

Durante el proceso de testing realizamos pruebas exploratorias con el fin de identificar vulnerabilidades comunes en aplicaciones web y evaluar las medidas de seguridad presentes en el sistema. Para ello, se utilizó la herramienta OWASP ZAP, ejecutando un escaneo pasivo que permitió detectar fallos de configuración y prácticas inseguras.

Entre las alertas generadas destacan la ausencia de tokens Anti-CSRF, lo cual podría permitir ataques de falsificación de solicitudes entre sitios; la cabecera Content Security Policy (CSP) no configurada, lo que facilita ataques como Cross-Site Scripting (XSS); y la presencia de cookies sin el flag HttpOnly, permitiendo el acceso a información sensible mediante scripts del lado del cliente.

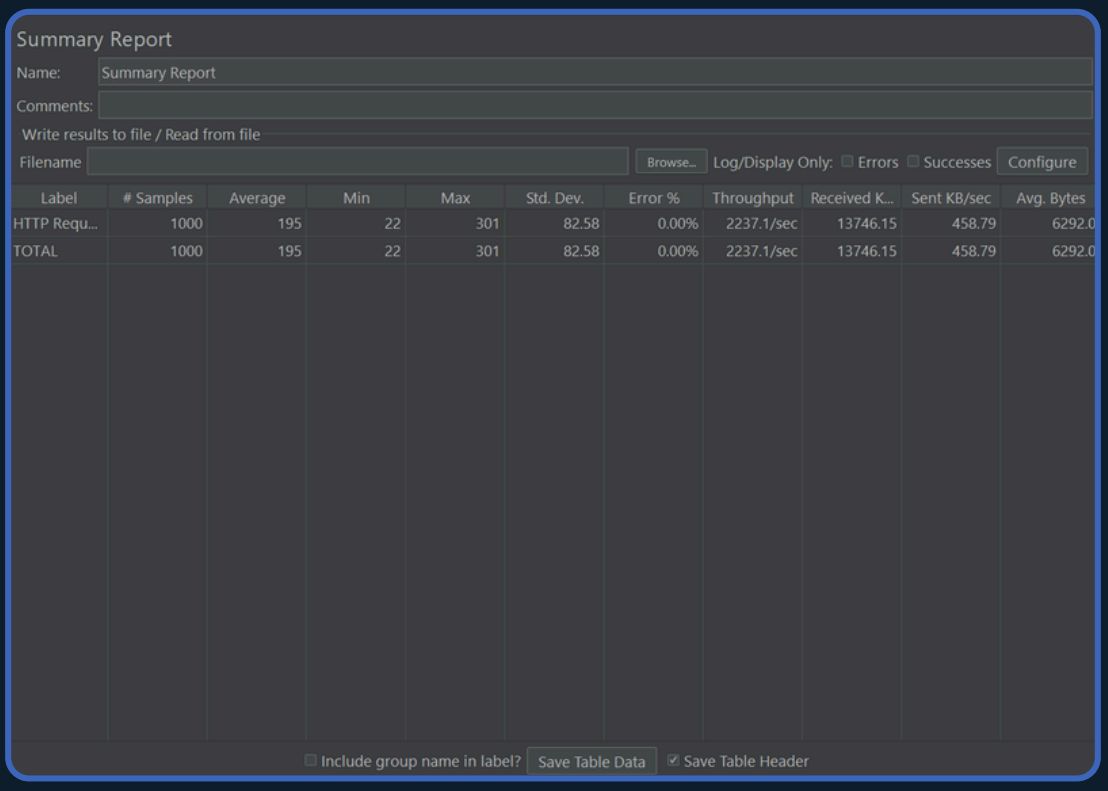


Pruebas de Rendimiento

Descripción:

Durante el proceso de testing realizamos pruebas de rendimiento con el objetivo de evaluar la capacidad de respuesta del sistema de gestión de notas de la UCS ante múltiples usuarios simultáneos. Para ello, se utilizó la herramienta Apache JMeter, configurando el plan de prueba con 1000 hilos, un período de subida (ramp-up period) de 0.5 segundos y un contador de bucle en 1. Esta configuración permitió simular mil usuarios accediendo casi al mismo tiempo.

La prueba consistió en enviar una solicitud HTTP de tipo POST a la URL "http://localhost/UCS-A/index.php", correspondiente al formulario de inicio de sesión del sistema. El reporte resumen de JMeter arrojó un porcentaje de error de 0.00%, lo que indica que todas las solicitudes fueron procesadas correctamente. Asimismo, se obtuvo un rendimiento de 120.5 peticiones por segundo, evidenciando que el sistema respondió de forma eficiente ante una carga alta de usuarios.



Observaciones y Recomendaciones



Visión General de lo Analizado

Seguridad

En materia de seguridad, el sistema presenta vulnerabilidades críticas como inyección SQL, que permite escalar privilegios y comprometer la integridad de los datos. También se detectaron fallas de tipo XSS y una ausencia generalizada de validación en los formularios, lo que expone el sistema a ataques comunes. Estas debilidades evidencian una falta de medidas básicas de protección. Es urgente implementar filtros de entrada, consultas preparadas y políticas de seguridad robustas.

Documentación

En cuanto a la documentación, esta es prácticamente inexistente, ya que el sistema no cuenta con manuales de usuario ni documentación técnica que describa su funcionamiento interno. Esta carencia dificulta la comprensión, uso y mantenimiento del sistema tanto para usuarios finales como para desarrolladores. Además, limita la posibilidad de escalar o corregir errores de forma eficiente. Es fundamental elaborar al menos una guía básica de usuario y un documento técnico para soporte futuro.

Código Fuente

El código fuente carece de una arquitectura o patrón de diseño definido, lo que genera desorden y dificulta su mantenimiento. Muchos archivos están desorganizados, lo que complica futuras modificaciones. Implementar buenas prácticas de desarrollo y patrones de diseño facilitaría la escalabilidad y el mantenimiento.

Visión General de lo Analizado

Rendimiento

El sistema muestra un rendimiento adecuado bajo cargas bajas a moderadas, como se evidenció en las pruebas realizadas con 1000 usuarios simultáneos, donde no se reportaron errores y se obtuvo un buen rendimiento de 120.5 peticiones por segundo. Sin embargo, es importante señalar que la estabilidad y los tiempos de respuesta pueden verse comprometidos a medida que el número de usuarios o transacciones aumenta significativamente

Control de Versiones

El sistema carece de control de versiones, lo que impide un seguimiento adecuado de los cambios en el código, dificulta la colaboración entre desarrolladores y complica la gestión de errores y nuevas funcionalidades. Implementar un sistema de control de versiones, como Git, es esencial para mejorar la trazabilidad y eficiencia en el desarrollo y mantenimiento del proyecto.

Legalidad

El sistema utiliza recursos de terceros, como imágenes con licencias de uso libre e imágenes institucionales, y está marcado bajo la licencia Creative Commons. A nivel de legalidad, no se presentan problemas evidentes. Sin embargo, se recomienda verificar y documentar todos los componentes utilizados, asegurándose de que el uso de cada uno sea completamente legal y cumpla con las licencias correspondientes.